

Guía de implementación del Marco de ciberseguridad 5.0

GR.1 Adoptar una metodología de Evaluación de Riesgo

Requisito GR.1	Adoptar una metodología de Evaluación de Riesgo
Objetivo	Establecer un proceso de evaluación de riesgo en base a una metodología que permita guiar a la organización por las buenas prácticas de la evaluación del riesgo a nivel tecnológico y de procesos; permitiendo establecer su apetito de riesgo, la tolerancia sobre las desviaciones, calcular la probabilidad de ocurrencia y el impacto potencial sobre la materialización de las vulnerabilidades.
Controles	Nivel 1 - GR.1-1: existe un proceso para la gestión de riesgos de seguridad de la información que abarca los componentes del centro de procesamiento de datos y servicios críticos de forma independiente. Nivel 2 - GR.1-2: se cuenta con una metodología de evaluación de riesgos de seguridad de la información definida y documentada. Nivel 3 - GR.1-3: existe una política aprobada de gestión de riesgos de seguridad de la información. - GR.1-4: la política de gestión de riesgos de seguridad de la información ha sido difundida a todas las partes interesadas. Nivel 4 - GR.1-5: la metodología de evaluación de riesgos es revisada periódicamente y ajustada en función de los resultados obtenidos, los cambios en el contexto organizacional o normativo, y las oportunidades de mejora identificadas en su aplicación.

Requisito GR.1	Adoptar una metodología de Evaluación de Riesgo
Guía de implementación	Se debe adoptar una metodología de evaluación de riesgo basado en la identificación de amenazas y vulnerabilidades, que pueda aplicarse a todos los aspectos tecnológicos, y que esté alineada a la gestión de riesgos de negocio de la organización. Dentro de los riesgos a identificar, deberán incluirse los riesgos positivos (es decir, las oportunidades estratégicas); de manera de permitir la discusión de estos aspectos en las evaluaciones de riesgos de ciberseguridad. Política Se debe definir una política de gestión de riesgos de seguridad de la información basada en una metodología de gestión de riesgos y definir el responsable de su gestión. Aprobación y difusión La política de gestión de riesgo debe ser o formar parte de la adopción de la política de Seguridad de la Información la cual debe ser aprobada por la Dirección y/o CSI.
Instituciones de salud	No aplica
Instituciones Emisoras de Dinero Electrónico (IEDE)	El órgano de dirección de la institución definirá, aprobará y supervisará todas las disposiciones relacionadas con el marco de gestión del riesgo. Los líderes de la organización son responsables de los riesgos de ciberseguridad y fomentan una cultura consciente de los riesgos, manteniendo una mejora continua en los procesos de gestión de riesgos. La institución cuenta con un seguro que cubre costos asociados a ciberataques.
Guía de evidencia para auditoría	• Metodología de gestión de riesgos de seguridad de la información (identificación, evaluación, tratamiento, seguimiento y comunicación a los interesados). • Política de gestión de riesgos de seguridad de la información. • Cuestionarios realizados al personal para corroborar el conocimiento de la Política de gestión de riesgo. • Registro de cambios a la Política de gestión de riesgo.
Normativa asociada	No aplica

GR.2 Realizar de manera sistemática el proceso de evaluación de riesgos →

[Ir al Índice](#)

Etiquetas

[Gestión y auditoría de Seguridad de la Información](#)

[Marco de Referencia](#)

[Política Digital del Uruguay](#)

[Políticas de Ciberseguridad](#)

[Ciberseguridad](#)

[Herramientas para la ciudadanía](#)

[Herramientas para organismos](#)

[Política Digital del Uruguay](#)

Índice

Introducción

Objetivo y Alcance

Requisitos

Organización y Gobernanza

Gestión de Riesgos

Gestión humana

Gestión de activos

Control de acceso

Seguridad física y del ambiente

Seguridad de las operaciones

Seguridad de las comunicaciones

Adquisición, desarrollo y mantenimiento de los sistemas

Relación con proveedores

Gestión de incidentes

Continuidad de las operaciones

Cumplimiento normativo y revisión

Protección de datos personales

Agencia de Gobierno Electrónico y Sociedad de la Información y del Conocimiento

Dirección: Liniers 1324 piso 4 (Montevideo, Uruguay)

Teléfono: (+598) 2901 2929

Contacto

Horario de atención: lunes a viernes de 9:00 a 17:00 h.

gub.uy

